Imran Pasha

Target Role: Penetration Tester / Ethical Hacker | Application Security
Sakleshpur, Karnataka, India | +91 9844548537 | imranpasha.ahmed@gmail.com
github.com/Imranpasha30 | imranportfolio.duckdns.org | tryhackme.com/p/devilhost666

PROFESSIONAL SUMMARY

Backend developer, nearly two years on production Python and FastAPI at one employer. Built a deliberately vulnerable RAG target outside work, four guardrail controls in front of it, and an OWASP LLM Top 10 attack harness around both. Reviewed the guardrail code afterwards and found an exfiltration path the ingest and retrieval controls both miss, because that check matches the literal word CONFIDENTIAL and the runbook holding the planted key is titled INTERNAL.

TECHNICAL SKILLS

Penetration Testing VAPT (Vulnerability Assessment and Penetration Testing), OWASP Top 10, SQL injection, cross-site scripting (XSS), IDOR and BOLA, Burp Suite, Nmap, Metasploit, Wireshark, Nessus/OpenVAS, Kali Linux
Application Security API security (OWASP API Security Top 10), secure SDLC, threat modeling (STRIDE), secure code review, SAST, DAST, SCA (software composition analysis), CVSS, CWE mapping
LLM Security and AI Red Teaming OWASP Top 10 for LLM Applications, prompt injection, indirect prompt injection, excessive agency (LLM06), data poisoning (LLM04), guardrails, RAG security, promptfoo config authoring
Engineering Python, FastAPI, Flask, JWT, authentication and authorization, REST API design, rate limiting, TLS, PostgreSQL, Redis, Docker, Linux

PROJECTS

LLM Red-Team Platform | github.com/Imranpasha30/llm-redteam-platform
Personal project. Vulnerable RAG target, four-control defense layer in 838 lines of Python, and an attack harness.

- Wrote four guardrail controls (scan_input, scan_output, harden_system_prompt, filter_chunks) and wired them at 4 of the 6 steps of the request path. A lazy import keeps the target runnable undefended, for baseline comparison.
- 35 hand-written signatures cover prompt injection, jailbreak framing, secret shapes and poisoned chunks. Input scanning folds NFKC and strips six invisible codepoints. Zero-width variants still match.
- No third-party dependencies. The whole layer imports re and unicodedata.
- Wrote custom Python assertions for LLM03 supply-chain provenance and LLM04 data poisoning. Supply-chain risk is a build-time property no prompt can elicit, and poisoning is visible only by effect.
- Configured a promptfoo harness of 18 attack plugins and 3 evasion strategies, with all ten OWASP LLM ids listed separately alongside bola, bfla and indirect prompt injection.
- Kept the lab safe by design. The only planted secret is a self-labelled canary, the fake staff records use the reserved 900-xx-xxxx SSN range, and the target defaults to a local endpoint.
- Not run yet. DEFENSES_ENABLED stays out of the harness config so one suite can drive a baseline and a defended run.

Cyber Security Capstone | Assessed coursework project for the Executive PG Certification | May 2026
Instructor-assessed written exercises on provided sample artifacts.

- Decoded a Base64 UTF-16LE PowerShell command line and reconstructed the dropper chain, .NET reflection to reach DownloadData, then the payload written into %ProgramData%. MITRE ATT&CK T1059.001, T1027.010, T1140, T1105.
- The execution step instantiates ShellBrowserWindow by CLSID and calls ShellExecute, which re-parents the payload under explorer.exe and breaks parent-child lineage detection.
- Specified a pre-release application security testing workflow for a secure SDLC. Scoping and STRIDE threat modeling first, then SAST, DAST and SCA, then penetration testing (VAPT) against the OWASP Top 10 and the OWASP API Security Top 10. Findings ranked by CVSS and mapped to a CWE.

WORK EXPERIENCE

Backend Developer, Sharkify Private Limited | India | Dec 2024 – Present

- Built JWT authentication on Voter Connect and secure API endpoints for campaign administrators and field volunteers, with geolocation verification on those endpoints.
- Added API rate limiting and exception handling across the FastAPI services, then PostgreSQL indexing and Redis caching to hold reads under a second over 9.9M+ voter records.
- Put the Shyra services in Docker behind NGINX doing TLS termination and rate limiting.
- Wrote the fan-out publisher on Kaizer X, keyed on SHA-256 so a retried job does not double-publish. The product ships behind 120+ feature flags, with output byte-identical to the frozen legacy baseline when off.

EDUCATION

B.Tech, Computer Science, Sahyadri College of Engineering (VTU) | 2020 – 2024

CERTIFICATIONS

Executive Post Graduate Certification in Cyber Security and Ethical Hacking, iHUB DivyaSampark at IIT Roorkee in association with Intellipaat | May 2026 | Certificate ID IPTIH26050044, verifiable at ihubtr.ac.in
Hands-on labs: 49 TryHackMe rooms covering web application testing, Burp Suite, Nmap, Metasploit, privilege escalation, SQL injection, cross-site scripting and IDOR.
Studying for the CEH exam. Not taken yet, and no credential claimed.